

Contents

1	FR24 監査・SLA	1
1.1	0. 文書情報	1
1.2	1. 機能概要	1
1.3	2. 収録 FR-NNN 一覧	1
1.4	3. 補足説明・統合参照	1
1.4.1	関連する NFR(監査・SLA 系)	1
1.4.2	SLA/障害対応 SLA 関連	2
1.4.3	業務要件との対応 (§ 7 BR-028)	2
1.4.4	監査ログコード体系	2
1.4.5	audit_logs.retention_class	2
1.5	4. 関連設計	2
1.6	5. 未確定事項・確認事項	2

1 FR24 監査・SLA

1.1 0. 文書情報

項目	内容
文書種別	機能要件(機能グループ別)
対象システム	運営者システム(顧客管理システム)
版	v1.0
機能グループ	監査・SLA(運営者責務のうち監査ログ閲覧・エクスポート・運営者活動ダッシュボード)
ソース章	§ 8.20 内 監査・SLA 関連 / § 12.6.1 / § 7 業務要件の関連
派生元 BR	BR-028(運営者の内部統制要件)

1.2 1. 機能概要

運営者操作の事後監査(操作者・操作元 IP・対応チケット ID・操作種別・対象・操作前後の値の記録)、運営者活動ダッシュボード(直近 90 日の時系列表示)、操作頻度異常の検知、監査ログ閲覧・検索・エクスポート機能(SCR-096)を扱う。本書側で正本管理する監査ログ閲覧・エクスポート機能(FR-232)もここに含める。

監査ログの保持期間は、(a)業務監査ログ = 1 年(NFR-602a)、(b)課金関連監査ログ = 7 年(NFR-602b、電帳法・国税法)、(c)運営者高権限操作監査ログ = 5 年(NFR-602d、SOX 類似・係争耐性)。完全性検証は日次バッチ(NFR-602c)。改ざん検知方式 = ハッシュチェーン(NFR-306、運営者側を正本)。

1.3 2. 収録 FR-NNN 一覧

ID	要件	優先度
FR-229	運営者操作の事後監査として、(a) 監査ログには操作者アカウント ID・操作元 IP(マスク可)・対応チケット ID・操作種別・対象・操作前後の値を記録すること、(b) 直近 90 日の運営者操作を時系列で運営者活動ダッシュボードで表示できること、(c) 操作頻度の異常(同一運営者による短時間での大量操作)を検知し、運営者全体に通知できること	P0
FR-232	運営者は監査ログを Web UI(SCR-096 運営者活動ダッシュボード(監査))で閲覧・検索・エクスポートできること。検索・エクスポート操作自体も監査ログに記録し、誰がどの条件で監査ログへアクセスしたかを追跡できること。検索項目、ページング、エクスポート形式、改ざん検知方式、上限超過時の扱いは基本設計 / 詳細設計を正本とする。派生元: BR-028	P0

1.4 3. 補足説明・統合参照

1.4.1 関連する NFR(監査・SLA 系)

- ・ **NFR-306**: 監査ログを改ざん検知可能な形で保持。レコード列改ざん検知バッチ・日次全件検証・不一致時の運営者高重要度通知・IP 匿名化(運営者側を正本)。
- ・ **NFR-602a**: 一般監査ログ(業務監査ログ)保持期間 = 1 年。期間経過後はメインシステム § 12.2.1 に従い本文物理削除しつつハッシュチェーン連続性を維持。
- ・ **NFR-602b**: 課金関連監査ログ保持期間 = 7 年(国税通則法・法人税法施行規則、電帳法)。真正性・可視性・検索性を確保。

- **NFR-602c:** 監査ログ完全性検証バッチを日次で全件検証。不一致検出時は新規追記を一時停止し運営者へ高重要度アラート。
- **NFR-602d:** 運営者高権限操作監査ログ保持期間=5年。対象9操作: (a) 削除データ復元、(b) 契約停止/復元/物理削除、(c) AI 推論パラメータ変更、(d) 契約別レート制限/予算上書き、(e) お知らせ配信、(f) 運営者アカウント発行/無効化、(g) 課金 Webhook リプレイ、(h) 本番直接変更、(i) 監査ログエクスポート操作。
- **NFR-603:** 監査ログには操作者・対象・時刻・IP(マスク可)を記録。
- **NFR-311:** 運営者画面(SCR-090~099)へのアクセスログは全件保持(サンプリング省略不可)、NFR-602dに従い5年。

1.4.2 SLA / 障害対応 SLA 関連

- **NFR-330(脆弱性対応 SLA):** Critical(CVSS 9.0 以上 / 既に悪用観測あり)= 24 時間以内 / High(CVSS 7.0~8.9)= 7 日以内 / Medium(CVSS 4.0~6.9)= 30 日以内 / Low(CVSS 4.0 未満)= 次定例リリース内。SLA 超過は運営者ダッシュボードで可視化し、超過事案は § 20.1 リスク管理の対象。
- **NFR-331(SCA 必須組込):** 依存ライブラリ脆弱性スキャンを CI に必須組込、週次フルスキャン実行。Critical 脆弱性が未対応のままリリースをブロック。
- **NFR-332(ペネトレーションテスト):** 年1回以上+ 重大機能変更時に追加実施。実施記録は監査対象として5年保持。
- **AC-036(PII 誤検出判定 SLA):** 運営者は3営業日以内に判定。
- **AC-041(Webhook 30 日リプレイ):** 直近30日のリプレイ実行が運営者操作から可能。

1.4.3 業務要件との対応 (§7 BR-028)

BR-028 は「サービス運営者は、内部統制(セキュリティ・コンプライアンス・障害対応・課金正確性)を担保するために必要な運用機能(監査ログ閲覧、削除データ復元、4-eyes 原則対象操作、契約単位の運営者操作通知など)を持つこと」を定める。本書 FR-229 / FR-232 はこの BR-028 を中核に派生する。

1.4.4 監査ログコード体系

監査ログの操作種別コードは「対象リソース」と「操作動詞」の組合せで一意に識別できる命名規則とする (§ 12.6)。具体命名規則・操作コード一覧は基本設計および詳細設計書を参照。メインシステムと顧客管理システムで共通の体系とし、両者の操作コードに重複・衝突がないこと。

1.4.5 audit_logs.retention_class

リポジトリ CLAUDE.md / 共有概念に従い、**audit_logs.retention_class** はクラス名表記 (**general / billing / operator_high_priv**) に統一する。人間可読補助としての期間表記 (**1y / 5y / 7y**) も併記可。

1.5 4. 関連設計

- [../02_基本設計/index.md](#) 基本設計書 index
- [../02_基本設計/01_画面設計.md](#) § SCR-096(運営者活動ダッシュボード(監査))
- [../02_基本設計/02_API設計.md](#) 監査ログ検索・エクスポート API
- [../02_基本設計/03_テーブル設計.md](#) **audit_logs** テーブル(ハッシュチェーン・retention_class)
- [../02_基本設計/05_エラー設計.md](#) 監査ログ完全性検証エラー(E-OP-AUTH-*)
- [../02_基本設計/09_セキュリティ設計.md](#) § 7 ハッシュチェーン監査(運営者側を正本) / 3 区分保持 / GDPR
- [../02_基本設計/07_トレーサビリティマトリクス.md](#)
- [../03_詳細設計/index.md](#) 詳細設計書 index

1.6 5. 未確定事項・確認事項

- FR-229(c) 操作頻度の異常(同一運営者の短時間大量操作)の具体しきい値は基本設計で確定する。
- FR-232 エクスポート形式(CSV / JSON / NDJSON)・件数上限は基本設計で確定する。
- 監査ログ完全性検証バッチの実行時刻(JST)は基本設計および運用手順書で確定する。